

## APC by Schneider Electric Firmware Attack Surface & Detection Brief

---

**Scope:** 3 product lines (NMC2 AP9630/9631/9635, NMC3 AP9640/9641/9643, Rack PDU 2G AP86xx) / ~241 unique hashes across 3 architecture classes (plus a 4th Windows-side class). Findings combine CVE/PSIRT research and direct examination of the extracted NMC firmware (catalog inventory, signed-image headers, embedded web UI strings). APC management cards are *not* large-rootfs Linux devices — they are compact firmware blobs (proprietary RTOS / embedded Linux derivative) with an embedded web/SSH/SNMP stack.

**Known coverage gap — Smart-UPS internal MCU firmware (Smart-UPS / SRT / SRTL family).**

The UPS controller firmware running on the Smart-UPS Online SRT board (SRT5KRMXLI, SRT5KXLT, SRT5KRMXLT30, and the rest of the SRT/SRTL line) is **NOT** in this catalog. The staging folder exists at `firmware-staging/APC/UPS/Smart-UPS-Online-SRT/raw/` but no binaries have been pulled yet. When extracted, this becomes a "Group E. Smart-UPS internal MCU" class — directly analogous to [Eaton brief Group D](#) (bare-metal UPS MCU `.sta` family). This gap matters because **CVE-2022-0715 — the third TLStorm CVE — targets the Smart-UPS internal firmware specifically, not the NMC**: it's the signature-check bypass on the firmware-upgrade path. Groups A and B reference it as the persistence anchor for the TLStorm chain, but the brief has no hashes to match a Smart-UPS internal firmware image against until SRT/SRTL firmware lands in staging. See [the Smart-UPS-Online-SRT staging README](#) for download pointers and extraction notes.

**Purdue layer mapping:** NMC2/NMC3/Rack PDU 2G live at **Purdue L3.5 (IT/OT Boundary)** as the SNMP+web bridge from corporate IT to OT power infrastructure; PowerChute / EcoStruxure IT runs at **Purdue L3 (Site Operations)**. See [purdue-l35-it-ot-boundary-brief.md](#) and [purdue-l3-site-operations-brief.md](#) for the cross-vendor views of those layers.

### Architecture grouping (drives the threat model, not the SKU)

---

| Class                   | Purdue layer        | Products               | Stack                                                                                | Catalog depth |
|-------------------------|---------------------|------------------------|--------------------------------------------------------------------------------------|---------------|
| <b>A. NMC3 (modern)</b> | L3.5 IT/OT Boundary | AP9640, AP9641, AP9643 | Signed firmware (ECDSA), embedded HTTPS/SSHv2/SNMPv3 web UI, "Trusted Platform" boot | 83 hashes     |

| Class                     | Purdue layer                                                                                                                    | Products                                                                                            | Stack                                                                                             | Catalog depth |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|---------------|
| <b>B. NMC2 (legacy)</b>   | L3.5 IT/OT Boundary                                                                                                             | AP9630, AP9631, AP9635                                                                              | Older APC web/SSH stack (Mocana NanoSSL), TLStorm-vulnerable lineage, no enforced signing pre-6.8 | 86 hashes     |
| <b>C. Rack PDU 2G NMC</b> | L3.5 IT/OT Boundary (with L1 outlet-actuation control plane)                                                                    | AP86xx Switched / Metered switched (AP8941, AP8959, AP8861, AP8865 etc.)                            | NMC variant with outlet-control firmware path; HTTPS/SSH/SNMPv3 + per-outlet control plane        | 72 hashes     |
| <b>D. Windows-side</b>    | L3 Site Operations (PCNS server); L4 corp-IT (PowerChute Personal/Business on user PCs); L3↔L4/L5 (EcoStruxure IT Expert cloud) | PowerChute Network Shutdown (PCNS), PowerChute Business / Personal, EcoStruxure IT Gateway / Expert | Java + Windows service stack the admin runs; reaches NMC via HTTPS/SNMP                           | research only |

## Group A — NMC3 AP964x (signed firmware, modern stack) — Purdue L3.5 (IT/OT Boundary)

**Direct attack surface (verified via signed-image header + embedded web UI strings in the extracted AP964x firmware):**

HTTPS (TLS 1.2/1.3) • SSHv2 • SNMPv3 (v1/v2c disabled by default in 2.x) • Modbus TCP/502 (opt-in) • RADIUS client • Syslog client • NTP client • FTP DISABLED by default • Trusted-Platform signed boot

The signed-image manifest shows ECDSA-P256 over the firmware payload; downgrade to unsigned NMC2-era images is rejected by the bootloader. SNMPv1/v2c and Telnet are present in the binary but ship disabled.

**Confirmed CVEs:**

| CVE                                                 | CVSS | Product                                 | Vector                                                                                                            | Status on the firmware you have                             |
|-----------------------------------------------------|------|-----------------------------------------|-------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|
| <a href="#">CVE-2022-22805</a>                      | 9.0  | NMC2/NMC3 TLS reassembly                | Memory-corruption RCE pre-auth via crafted TLS packets ("TLStorm" #1)                                             | <b>Fixed in NMC3 ≥ 1.1.0.16</b> — verify your catalog floor |
| <a href="#">CVE-2022-22806</a>                      | 9.0  | NMC2/NMC3 TLS state-confusion           | Auth bypass during TLS handshake ("TLStorm" #2)                                                                   | Same — confirm catalog hashes map to patched build          |
| Schneider PSIRT — Easergy / Galaxy mgmt-iface class | —    | Schneider mgmt-plane Java-RMI bug class | Missing-auth on critical methods — same Java-RMI exposure pattern PowerChute mgmt agents have historically shared | <a href="#">Schneider PSIRT portal</a> — research only      |

**Top attack vector (MITRE ATT&CK ICS):** [T0857 System Firmware](#) — even with signed firmware, the TLStorm class showed that the TLS *parser* is the pre-auth attack surface; firmware signing protects the flash path, not the live network parser.

## Group B — NMC2 AP963x (the TLStorm legacy) — Purdue L3.5 (IT/OT Boundary)

**Direct attack surface (verified via embedded strings + cgi-bin paths in extracted AP963x firmware):**

HTTPS (older OpenSSL/Mocana NanoSSL) • SSHv1/v2 • Telnet (default enabled on pre-6.0.6) •  
 FTP (default enabled pre-6.x — used as firmware-upload channel) • SNMPv1/v2c (community public/private) •  
 Modbus TCP/502 • BACnet/IP UDP/47808 (opt-in) • web UI superuser `apc` / `apc`

Default `apc / apc` credentials are baked into factory state. FTP-based firmware push ( `nmc_*.bin` over FTP) is the historical update path — no signature enforcement on AP963x below firmware 6.8.

### Confirmed CVEs:

| CVE                            | CVSS | Product                                 | Vector                                                                   | Status on the firmware you have                                                     |
|--------------------------------|------|-----------------------------------------|--------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| <a href="#">CVE-2022-22805</a> | 9.0  | NMC2 (Mocana NanoSSL packet-reassembly) | Pre-auth RCE via crafted TLS — TLStorm #1, <a href="#">Armis writeup</a> | <b>Fixed in NMC2 ≥ 6.9.6</b> — anything older in your 86-hash catalog is vulnerable |

| CVE                                 | CVSS | Product                                    | Vector                                                                 | Status on the firmware you have                         |
|-------------------------------------|------|--------------------------------------------|------------------------------------------------------------------------|---------------------------------------------------------|
| <a href="#">CVE-2022-22806</a>      | 9.0  | NMC2 TLS state-confusion                   | Auth bypass — TLStorm #2                                               | Same fix line — verify                                  |
| <a href="#">CVE-2022-0715</a>       | 8.9  | NMC2/NMC3 firmware-upgrade signature check | Unsigned firmware accepted → arbitrary code persistence ("TLStorm" #3) | The reason AP963x ≤ 6.7 cannot trust its own flash path |
| <a href="#">CISA ICSA-22-083-01</a> | —    | APC Smart-UPS family (TLStorm bundle)      | Authoritative advisory bundling the three TLStorm CVEs                 | Reference                                               |

**Top attack vector (MITRE ATT&CK ICS):** [T0866 Exploitation of Remote Services](#) (TLStorm pre-auth on TLS) chained into [T0857 System Firmware](#) (CVE-2022-0715 lets the post-RCE payload survive reboot as legitimate firmware).

## Group C — Rack PDU 2G AP86xx — Purdue L3.5 (IT/OT Boundary) with L1 outlet-actuation

The 72-hash AP86xx catalog is an NMC variant retargeted for switched/metered PDU outlet control. Stack is the same family as NMC2/NMC3, so the *same* TLStorm CVE class applies depending on which generation the AP86xx unit shipped with.

### Direct attack surface (verified via extracted AP86xx firmware strings):

```
HTTPS/SSH/SNMPv3 web UI • per-outlet ON/OFF/CYCLE control endpoints • SNMP `epdu` MIB
(rPDU2OutletSwitchedControlCommand, rPDU2OutletSwitchedConfigPowerOnDelay)
```

### Attack vectors:

- **Outlet-control via SNMP** `set` to `rPDU2OutletSwitchedControlCommand` — set value=2 (outletOff) is the destructive single-OID write. SNMPv1/v2c with default community here = single-packet rack power-off.
- **TLStorm parser bug** is the same Mocana stack — AP86xx firmware predating the 2022 fix line is RCE-exploitable.
- **Mass-PDU coordinated outlet shutdown** as an availability/destructive ICS attack — explicitly modeled by CISA in the 2022 internet-exposed-UPS advisory.

**Top attack vector (MITRE ATT&CK ICS):** [T0879 Damage to Property](#) via [T0855 Unauthorized Command Message](#) — single SNMP write disables an entire rack.

---

## Group D — PowerChute / EcoStruxure IT (Windows-side) — Purdue L3 (Site Operations) with L4 corp-IT + L4/L5 cloud edges

---

| CVE                                                              | CVSS | Product                     | Vector                                                                                                                     |
|------------------------------------------------------------------|------|-----------------------------|----------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2021-22812</a>                                   | 9.8  | PowerChute Business Edition | Unauth RCE via deserialization in management agent                                                                         |
| <a href="#">CVE-2021-22813</a>                                   | 7.5  | PowerChute Business Edition | Auth bypass on local web mgmt                                                                                              |
| Schneider PSIRT — PowerChute Serial Shutdown local-privesc class | 7.x  | PowerChute Serial Shutdown  | Local privilege escalation via insecure directory / service-permissions class — see <a href="#">Schneider PSIRT portal</a> |
| Schneider PSIRT — EcoStruxure IT Gateway mgmt-plane class        | 7.x  | EcoStruxure IT Gateway      | Auth/management-plane vuln class — see <a href="#">Schneider PSIRT portal</a>                                              |

If a Windows admin host runs PowerChute / EcoStruxure IT below the current PSIRT-fixed build, that host is the foothold path to every AP963x/AP964x/AP86xx it manages.

---

## Logging matrix (highest priority)

---

Top 8 — ordered by detection value per ingest dollar:

| # | Source               | Event                                                                       | What it catches                                   | MITRE ATT&CK ICS                          |
|---|----------------------|-----------------------------------------------------------------------------|---------------------------------------------------|-------------------------------------------|
| 1 | NMC syslog (UDP/514) | User logged in followed within 60s of repeated Authentication failed        | Brute-force success on apc / apc OR rotated creds | <a href="#">T0812 Default Credentials</a> |
| 2 | NMC syslog           | Firmware updated outside change-window OR firmware version <i>downgrade</i> | TLStorm-class persistence (CVE-2022-0715)         | <a href="#">T0857 System Firmware</a>     |
| 3 | NMC syslog           | Configuration changed + User created + SNMP community modified within 5 min | Persistence + parameter modification              | <a href="#">T0836 Modify Parameter</a>    |

| # | Source                             | Event                                                                                                                       | What it catches                              | MITRE ATT&CK ICS                                      |
|---|------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|----------------------------------------------|-------------------------------------------------------|
| 4 | <b>Network IDS (Suricata/Zeek)</b> | SNMP <code>Set-Request</code> to <code>rPDU20outletSwitchedControlCommand</code> from non-mgmt-VLAN source                  | Direct outlet-off attack on AP86xx           | <a href="#">T0855 Unauthorized Command Message</a>    |
| 5 | Network IDS                        | TLS handshake to NMC IP with abnormal record length / fragmented ClientHello                                                | TLStorm CVE-2022-22805/22806 exploit traffic | <a href="#">T0866 Exploitation of Remote Services</a> |
| 6 | Network IDS                        | Modbus function codes 5/6/15/16 crossing mgmt→OT boundary toward NMC                                                        | Control-logic tamper                         | <a href="#">T0833 Modify Control Logic</a>            |
| 7 | <b>Sysmon on PowerChute hosts</b>  | EventID 1 where ParentImage= <code>PowerChute*.exe</code> AND child is <code>cmd.exe / powershell.exe / rundll32.exe</code> | CVE-2021-22812 deserialization post-ex       | T1059 (Enterprise)                                    |
| 8 | Sysmon                             | EventID 11 (FileCreate) of <code>nmc_*.bin</code> / <code>apc_hw*.bin</code> on PowerChute / admin host outside maintenance | Staged tampered firmware ready to push       | <a href="#">T0857 System Firmware</a>                 |

## Secondary:

- Firewall: any egress from NMC/PDU VLANs to non-RFC1918 — APC NMCs should never originate outbound to the internet; the 2022 CISA UPS advisory called this out as the primary internet-exposure path.
- NMC native audit log: enable `Logs → Config → Audit Log` and forward via syslog. Categories: `Auth`, `Config`, `System`, `Event`. NMC3 also emits `Trusted Platform` boot-failure events — pipe those.
- SNMP trap collector: subscribe to `upsBasicTrapsOnBattery`, `upsAdvBatteryReplaceIndicator`, `rPDU20outletSwitchedStatusState`. Correlate sudden battery-test or outlet-off events with maintenance windows.
- OT-native: load drop >30% on a UPS with no scheduled change → possible `Outlet Off` SNMP/BACnet write; output frequency drift > ±0.5Hz → control-loop tampering precursor.

## Specific zero-day-ish concerns for your dataset

1. **TLStorm catalog-floor check.** Of the 86 NMC2 and 83 NMC3 hashes extracted, anything predating NMC2 6.9.6 / NMC3 1.1.0.16 is exploitable by CVE-2022-22805/22806/0715. Map

every hash to its embedded firmware-version string and flag anything below those floors — TLStorm is a *single packet* pre-auth chain.

2. **AP86xx outlet-control SNMP exposure.** A single SNMP `set` to `rPDU20outletSwitchedControlCommand` with value=2 powers off a rack. AP86xx units shipped historically with SNMPv1 `private` write community enabled. Audit your 72-hash AP86xx catalog for default-community config blocks (string `private` in the SNMP config region).
3. **Signed-firmware ≠ signed-parser.** Even fully-patched NMC3 AP964x firmware is still a network parser exposed to untrusted TLS bytes. TLStorm proved the *parser* is the surface; treat any pre-auth crash signal from a Suricata `tls-anomalous-record-length` rule as a real CVE-class event, not a benign scanner.
4. **PowerChute as the lateral path.** PowerChute hosts hold credentials/TLS trust to every NMC they manage. CVE-2021-22812 deserialization on PowerChute Business Edition → push tampered NMC firmware via the legitimate update channel → CVE-2022-0715-style persistence on every card.

---

## Sources

---

- [CISA — Mitigating Attacks Against UPS Devices \(2022\)](#)
- [CISA ICSA-22-083-01 — APC Smart-UPS \(TLStorm\)](#)
- [Armis — TLStorm research \(3 zero-days in APC Smart-UPS\)](#)
- [Schneider Electric Cybersecurity Support Portal / PSIRT](#)
- [Schneider PSIRT — Security Notifications index](#)
- [NVD — CVE-2022-22805](#)
- [NVD — CVE-2022-22806](#)
- [NVD — CVE-2022-0715](#)
- [NVD — CVE-2021-22812 \(PowerChute Business\)](#)
- [NVD — CVE-2021-22813 \(PowerChute Business\)](#)
- [APC NMC Security Handbook \(default creds + hardening\)](#)
- [MITRE ATT&CK for ICS — T0857 System Firmware](#)
- [MITRE ATT&CK for ICS — T0855 Unauthorized Command Message](#)
- [MITRE ATT&CK for ICS — T0866 Exploitation of Remote Services](#)
- [MITRE ATT&CK for ICS — T0812 Default Credentials](#)
- [MITRE ATT&CK for ICS — T0836 Modify Parameter](#)
- [MITRE ATT&CK for ICS — T0833 Modify Control Logic](#)
- [MITRE ATT&CK for ICS — T0879 Damage to Property](#)
- [Forescout 2025 OT Threat Report — power-infrastructure targeting trends](#)
- [CISA/NSA/FBI/ASD — Best Practices for Event Logging and Threat Detection \(2024\)](#)